CISO Conversation Guide — Demo-3 Edition

Translating B-V-R into Board Language for a Stateful, Three-Tier World

DEFCON Coimbatore 2026 · Venugopal Parameswara

> *"The board doesn't care about CVEs. They care about whether the business survives."*

What Changed Between Demo-2 and Demo-3

Demo-2 showed a single stateless tier respawn in 2 seconds. Your board will ask the obvious follow-up: *"Great — but what about the database? What about session state? What about the WAF?"* Demo-3 answers that question, and this guide is how you walk it back to the corner office.

The B-V-R framing doesn't change. The surface area does. You now have **R_1, R_2, R_3** — one per tier — plus a **combined cascade MTTR** for the worst case. If you can't explain those four numbers in plain English to a non-technical executive, you haven't internalised the model yet.

The Core Translation Table (Expanded)

Technical concept	Board / CFO language	Why it lands
B — Bleed Rate	"Revenue at risk per minute of downtime"	Dollar sign on every security decision
V — Attacker Velocity	"Time our team has before it's game over"	Urgency without crying wolf
R — MTTR	"How fast we restore normal operations"	The question the CEO actually asks
R < V	"We recover faster than an attacker pivots"	Binary win/lose — executives love this
R_1 / R_2 / R_3	"Recovery time per layer — web, app, data"	Mirrors how execs already think about the stack
Combined cascade (C)	"Worst-case bleed if every layer fails at once"	The only number disaster-recovery auditors care about
Immutable infrastructure	"Read-only production — factory-reset every deploy"	Compliance recognises this
Golden image	"Signed, verified software baseline"	ISO 27001 A.12.1.2 language
Fence-and-resume (DB)	"Automatic quarantine of the data replica when write patterns look like ransomware"	Direct answer to "can we stop NotPetya on the database?"
Stateless respawn	"Throw away the broken copy, start a new one — 0.6 seconds"	The Maersk-wouldn't-have-happened comparison
State loss vs data preservation	"Users log back in; money doesn't disappear"	The operational trade-off every COO understands

---

The 7 Questions a CISO Should Ask Their Team (Demo-3 Version)

Demo-2's five questions still stand. Demo-3 adds two more that a stateful stack forces you to confront.

Question 1 — The Bleed Rate Question

"What is our revenue-at-risk per minute for our three most critical services?"

Good: "Tier-1 banking transactions: ₹34,000/min. Tier-1 customer-facing app: ₹28,000/min. Tier-2 internal admin: ₹4,000/min." **Bad:** "Those are all critical systems." **Why it matters:** Without B, security prioritisation is gut feel.

Question 2 — The Velocity Question

"How long would a real red team take from initial container access to a full-stack wipeout — web, app, and data?"

Good: "Our October exercise: web wipeout in 47s, app kill in 62s, DB encryption in 4 minutes. Full-stack at about 6 minutes." **Bad:** "We haven't red-teamed the full stack — only the web tier." **Why it matters:** If your V is only measured on the easy tier, you're measuring the wrong thing.

Question 3 — The MTTR Question (Per Tier)

"What's our measured MTTR for the web, app, and database layers — independently?"

Good: "Web: 0.6s automated. App: 0.8s automated. DB: 12s fence-and-resume automated; full promote path is manual and takes 3 minutes." **Bad:** "We have a 99.9% uptime SLA." **Why it matters:** Three numbers, not one. Uptime SLA is an accounting metric; MTTR is an engineering metric.

Question 4 — The Automation Question

"If our primary Tier-1 service goes dark at 2am on a Saturday, does recovery require a human to be paged?"

Good: "Web and app: no human. DB fence-and-resume: no human. DB full promote: human, currently 15-min P95." **Bad:** "Yes, our on-call engineer logs in." **Why it matters:** Human MTTR is never under 5 minutes. Every human-in-the-loop layer is a bleed-rate multiplier.

Question 5 — The Chaos Question

"When did we last intentionally break every Tier-1 service in production to test recovery?"

Good: "GameDay three weeks ago covered web, app, DB separately, and then a cascade. C = 14s. Found a fence-timing gap and patched it." **Bad:** "We don't break production systems intentionally." **Why it matters:** You only know R under real conditions after you've measured it.

Question 6 — The State Question (NEW for Demo-3)

"For each Tier-1 service, which state will we lose during an automated recovery, and is that acceptable?"

Good: "App tier: in-memory sessions — users re-authenticate, acceptable. DB tier: committed transactions preserved, in-flight transactions rolled back, acceptable. Cache tier: invalidated, cold-hit latency spike for ~30s, acceptable." **Bad:** "Recovery preserves everything." *(This is a lie. Something is always lost. If nobody has thought about what, you find out during a real incident.)* **Why it matters:** Graceful fail is a design choice about which state survives. That choice has to be named, documented, and signed off — not discovered.

Question 7 — The Data-Corruption Question (NEW for Demo-3)

"How fast can we detect and contain a ransomware-style write storm on our primary database — before the corruption replicates?"

Good: "Guardian detects write velocity > 500 rows/sec. Replica is fenced via `pg_wal_replay_pause` within 1 second. ~500 rows of the initial bulk INSERT reach the replica before fence engages. We know this gap, and we're moving to logical replication with sub-100ms CDC to close it." **Bad:** "We have backups." **Why it matters:** Backups are the last resort. Real defence is catching the anomaly at write time, not restoring from tape at 3am.

How to Pitch B-V-R to Leadership — Demo-3 Version

The 90-Second Stateful Pitch

> *"Today, our security posture is built around prevention — keeping attackers out. That's necessary, but not sufficient. Every organisation with a meaningful attack surface will eventually be breached. The question isn't 'if' — it's 'what happens when.'*
>
> *I want us to adopt Mean Time to Recovery — measured per layer — as a first-class KPI. Specifically:* ***web R, app R, and data R.***
>
> *For our flagship service, our current web MTTR is acceptable — under a second, automated. Our app MTTR is acceptable. Our database MTTR for a ransomware-style write storm is 12 seconds today, because we auto-fence the replica when write patterns cross a threshold.*
>
> *Our bleed rate is ₹34,000 per minute. A ransomware incident that we currently size at 4 hours of downtime — our last tabletop — costs us ₹8 million. The automation I'm proposing brings that closer to 12 seconds of measured impact.* ***That's a 4-hour-to-12-second delta, at ₹34,000/min, worth roughly ₹8 million per incident prevented.***
>
> *The automation is running in a proof-of-concept today. I want 90 days and a specific team to productise it."*

The Numbers to Have Ready

Before the meeting, prepare a one-page brief with:

- **B** per Tier-1 service (3 numbers)
- **V** for each service from your last red-team (3 numbers)
- **R_1 R_2 R_3** from your last GameDay (9 numbers — three tiers × three services)
- **Combined cascade C** (3 numbers — one per service)
- Last major incident cost (downtime + remediation + regulatory + reputational)

- Cost of the proposed solution (infrastructure + tooling + training)
- Break-even analysis: *X incidents prevented pays for the programme*

Career Path Update — The Resilience Engineer (Demo-3 Version)

Demo-2's path still holds. Demo-3 adds one more rung:

```
SOC Analyst (L1/L2)
  ↓ Learn: Alert triage, SIEM, incident playbooks
  ↓ Key skill: MITRE ATT&CK, especially T1485, T1486, T1190

Security Engineer
  ↓ Learn: Hardening, vulnerability management, automation
  ↓ Key skill: Bash + Python, CI/CD security

Cloud Security Engineer
  ↓ Learn: IAM, network security, container security
  ↓ Key skill: IaC, Kubernetes, immutable infra

Resilience Engineer (SRE + Security)
  ↓ Learn: Chaos engineering, MTTR optimisation, golden images
  ↓ Key skill: Combining SRE principles with security posture

Data Resilience Engineer  ← NEW in the Demo-3 era
  ↓ Learn: PostgreSQL replication, WAL analysis, CDC, Patroni/Stolon
  ↓ Key skill: Detecting corruption at write-time, not at backup-time

CISO / Cyber Strategist
     Learn: Business context, board communication, risk quantification
     Key skill: B-V-R thinking — per-layer translation into business language
```

The fastest path: Run Demo-3 on your own machine. Extend `guardian3.sh` to catch a new ransomware variant. Ship the patch. Present at your next engineering all-hands. That's 80% of the practical skill.

Talking Points — Different Audiences

For a CTO

"We can make each layer of our stack recover faster than a human can notice. The code is running in a proof-of-concept today. I need a team to productise it — not to invent it."

For a CFO

"Our current MTTR for a Tier-1 incident is 47 minutes. At our bleed rate of ₹34,000/min, that's ₹16 lakh per incident. This automation brings web and app MTTR under 1 second and DB MTTR to ~12

seconds. That converts a ₹16 lakh exposure per incident into a ₹7,000 exposure. ROI is ~220:1 on a per-incident basis, and we have 4-6 of these per year."

For a Board Member

"We've shifted from hoping we don't get hit to knowing we recover in seconds when we do. Imagine replacing a fireproof building with a sprinkler system that activates in 2 seconds. The building still catches fire — but you save the contents, the staff, and the trust."

For a Developer

"Immutable infrastructure means you never SSH into production. Every deployment is a fresh container from a signed image. Your local build is the truth; production is just a copy. The database is the one exception — and even there, we treat the replica as disposable."

For a Compliance Officer

"Every container is spawned from a signed, audited, immutable image. No runtime modifications possible. DB replication is streaming and auditable. WAF blocks are logged to ModSecurity audit. Every incident is timestamped with a `mttr_ms` *field. MTTR is measured, not estimated. This satisfies availability + integrity requirements in ISO 27001 A.17, SOC 2 Availability TSC, and PCI DSS 10.5.3."*

For a Data Protection Officer (NEW for Demo-3)

"The DB fence mechanism means that during a ransomware write storm, corruption is contained to the primary for ~12 seconds before propagation is paused. Our RTO for a data-corruption incident is measured in seconds — not hours — and the replica is provably at a clean LSN we can verify with `pg_is_wal_replay_paused()`*. For GDPR Article 32 'ability to restore availability and access to personal data in a timely manner,' this is direct evidence."*

The Honest Conversation

When you pitch this, a senior exec will push back with one of three objections. Have the answer ready.

"This is just marketing for chaos engineering."

Answer: Chaos engineering is the method. B-V-R is the metric. You can do chaos engineering with no metric and call any uptime number a success. B-V-R forces you to state *per-tier MTTR targets in seconds* and report *whether you beat them*. That's harder to fake.

"Our vendor says their product gives us 99.999% uptime."

Answer: 99.999% uptime allows 5 minutes of downtime per year — **distributed how?** One 5-minute outage in one incident is fine. Five 1-minute outages across five incidents, each costing

₹34,000, is a different story. Your vendor is reporting an SLA; MTTR is the per-incident recovery measurement that SLA hides.

"We've never had a breach."

Answer: Neither had Maersk, British Airways, MGM, or Clorox — until the day they did. The point of B-V-R is that it's the only security metric whose value *increases* the more you measure it. Blocked attack counts are vanity. Prevented bleed in dollars is the real number, and you can't know it until you've measured MTTR.

DEFCON Coimbatore 2026 · Demo-3 · Venugopal Parameswara · CISO & Cyber Strategist